

CEH v13 Dump

1. Dorian is sending a digitally signed email to Poly. With which key is Dorian signing this message and how is Poly validating it?

A. Dorian is signing the message with his public key, and Poly will verify that the message came from Dorian by using Dorian's private key.

B. Dorian is signing the message with Poly's private key, and Poly will verify that the message came from Dorian by using Dorian's public key.

C. Dorian is signing the message with his private key, and Poly will verify that the message came from Dorian by using Dorian's public key.

D. Dorian is signing the message with Poly's public key, and Poly will verify that the message came from Dorian by using Dorian's public key.

2. Sophia is a shopping enthusiast who spends significant time searching for trendy outfits online. Clark, an attacker, noticed her activities several times and sent a fake email containing a deceptive page link to her social media page displaying all-new and trendy outfits. In excitement, Sophia clicked on the malicious link and logged in to that page using her valid credentials. Which of the following tools is employed by Clark to create the spoofed email?

A. Evilginx

B. Slowloris

C. PLCinject

D. PyLoris

3. John, a disgruntled ex-employee of an organization, contacted a professional hacker to exploit the organization. In the attack process, the professional hacker installed a scanner on a machine belonging to one of the victims and scanned several machines on the same

network to identify vulnerabilities to perform further exploitation. What is the type of vulnerability assessment tool employed by John in the above scenario?

A. Agent-based scanner

B. Network-based scanner

C. Cluster scanner

D. Proxy scanner

4. Joel, a professional hacker, targeted a company and identified the types of websites frequently visited by its employees. Using this information, he searched for possible loopholes in these websites and injected a malicious script that can redirect users from the web page and download malware onto a victim's machine. Joel waits for the victim to access the infected web application so as to compromise the victim's machine. Which of the following techniques is used by Joel in the above scenario?

A. Watering hole attack

B. DNS rebinding attack

C. MarioNet attack

D. Clickjacking attack

5. Jane, an ethical hacker, is testing a target organization's web server and website to identify security loopholes. In this process, she copied the entire website and its content on a local drive to view the complete profile of the site's directory structure, file structure, external links, images, web pages, and so on. This information helps Jane map the website's directories and gain valuable information. What is the attack technique employed by Jane in the above scenario?

A. Session hijacking

B. Website mirroring

C. Website defacement

D. Web cache poisoning

6. Mason, a professional hacker, targets an organization and spreads Emotet malware through malicious script. After infecting the victim's device, Mason further used Emotet to spread the infection across local networks and beyond to compromise as many machines as possible. In this process, he used a tool, which is a self-extracting RAR file, to retrieve information related to network resources such as writable share drives. What is the tool employed by Mason in the above scenario?

A. NetPass.exe

B. Outlook scraper

C. WebBrowserPassView

D. Credential enumerator

7. Which of the following protocols can be used to secure an LDAP service against anonymous queries?

A. NTLM

B. RADIUS

C. WPA

D. SSO

8. Security administrator John Smith has noticed abnormal amounts of traffic coming from local computers at night. Upon reviewing, he finds that user data have been exfiltrated by an attacker. AV tools are unable to find any malicious software, and the IDS/IPS has not reported

on any non-whitelisted programs. What type of malware did the attacker use to bypass the company's application whitelisting?

- A. File-less malware**
- B. Zero-day malware
- C. Phishing malware
- D. Logic bomb malware

9. What piece of hardware on a computer's motherboard generates encryption keys and only releases a part of the key so that decrypting a disk on a new piece of hardware is not possible?

- A. CPU
- B. UEFI
- C. GPU
- D. TPM**

10. Garry is a network administrator in an organization. He uses SNMP to manage networked devices from a remote location. To manage nodes in the network, he uses MIB, which contains formal descriptions of all network objects managed by SNMP. He accesses the contents of MIB by using a web browser either by entering the IP address and Lseries.mib or by entering the DNS library name and Lseries.mib. He is currently retrieving information from an MIB that contains object types for workstations and server services. Which of the following types of MIB is accessed by Garry in the above scenario?

- A. LNMIB2.MIB**
- B. DHCP.MIB
- C. MIB_II.MIB

D. WINS.MIB

11. Attacker Steve targeted an organization's network with the aim of redirecting the company's web traffic to another malicious website. To achieve this goal, Steve performed DNS cache poisoning by exploiting the vulnerabilities in the DNS server software and modified the original IP address of the target website to that of a fake website. What is the technique employed by Steve to gather information for identity theft?

A. Pharming

B. Skimming

C. Pretexting

D. Wardriving

12. Hackers often raise the trust level of a phishing message by modeling the email to look similar to the internal email used by the target company. This includes using logos, formatting, and names of the target company. The phishing message will often use the name of the company CEO, President, or Managers. The time a hacker spends performing research to locate this information about a company is known as?

A. Exploration

B. Investigation

C. Reconnaissance

D. Enumeration

13. A rootkit is a clandestine computer program designed to provide continued privileged access to a computer while actively hiding its presence. They are classified according to the place of their injection. What type of rootkit loads itself underneath the computer's operating system and can intercept hardware calls made by the original operating system.

A. Application rootkit

B. Kernel mode rootkits

C. Hypervisor (Virtualized) Rootkits

D. Memory rootkit

14. To create a botnet, the attacker can use several techniques to scan vulnerable machines. The attacker first collects information about a large number of vulnerable machines to create a list. Subsequently, they infect the machines. The list is divided by assigning half of the list to the newly compromised machines. The scanning process runs simultaneously. This technique ensures the spreading and installation of malicious code in little time. Which technique is discussed here?

A. Subnet scanning technique

B. Permutation scanning technique

C. Hit-list scanning technique.

D. Topological scanning technique

15. Jim, a professional hacker, targeted an organization that is operating critical industrial infrastructure. Jim used Nmap to scan open ports and running services on systems connected to the organization's OT network. He used an Nmap command to identify Ethernet/IP devices connected to the Internet and further gathered information such as the vendor name, product code and name, device name, and IP address. Which of the following Nmap commands helped Jim retrieve the required information?

A. `nmap -Pn -sT --scan-delay 1s --max-parallelism 1 -p < Port List > < Target IP >`

B. `nmap -Pn -sU -p 44818 --script enip-info < Target IP >`

C. `nmap -Pn -sT -p 46824 < Target IP >`

D. `nmap -Pn -sT -p 102 --script s7-info < Target IP >`

16. Alice, a professional hacker, targeted an organization's cloud services. She infiltrated the target's MSP provider by sending spear-phishing emails and distributed custom-made malware to compromise user accounts and gain remote access to the cloud service. Further, she accessed the target customer profiles with her MSP account, compressed the customer data, and stored them in the MSP. Then, she used this information to launch further attacks on the target organization. Which of the following cloud attacks did Alice perform in the above scenario?

- A. Cloud cryptojacking
- B. Man-in-the-cloud (MITC) attack
- C. Cloud hopper attack**
- D. Cloudborne attack

17. Stella, a professional hacker, performs an attack on web services by exploiting a vulnerability that provides additional routing information in the SOAP header to support asynchronous communication. This further allows the transmission of web-service requests and response messages using different TCP connections. Which of the following attack techniques is used by Stella to compromise the web services?

- A. Web services parsing attacks
- B. WS-Address spoofing**
- C. SOAPAction spoofing
- D. XML injection

18. Eric, a cloud security engineer, implements a technique for securing the cloud resources used by his organization. This technique assumes by default that a user attempting to access

the network is not an authentic entity and verifies every incoming connection before allowing access to the network. Using this technique, he also imposed conditions such that employees can access only the resources required for their role. What is the technique employed by Eric to secure cloud resources?

- A. Demilitarized zone
- B. Zero trust network**
- C. Serverless computing
- D. Container technology

19. Which IOS jailbreaking technique patches the kernel during the device boot so that it becomes jailbroken after each successive reboot?

- A. Tethered jailbreaking
- B. Semi-untethered jailbreaking
- C. Semi-tethered jailbreaking
- D. Untethered jailbreaking**

20. Johnson, an attacker, performed online research for the contact details of reputed cybersecurity firms. He found the contact number of sibertech.org and dialed the number, claiming himself to represent a technical support team from a vendor. He warned that a specific server is about to be compromised and requested sibertech.org to follow the provided instructions. Consequently, he prompted the victim to execute unusual commands and install malicious files, which were then used to collect and pass critical information to Johnson's machine. What is the social engineering technique Steve employed in the above scenario?

- A. Diversion theft
- B. Quid pro quo**

C. Elicitation

D. Phishing

21. Joe works as an IT administrator in an organization and has recently set up a cloud computing service for the organization. To implement this service, he reached out to a telecom company for providing Internet connectivity and transport services between the organization and the cloud service provider. In the NIST cloud deployment reference architecture, under which category does the telecom company fall in the above scenario?

A. Cloud consumer

B. Cloud broker

C. Cloud auditor

D. Cloud carrier

22. In this form of encryption algorithm, every individual block contains 64-bit data, and three keys are used, where each key consists of 56 bits. Which is this encryption algorithm?

A. IDEA

B. Triple Data Encryption Standard

C. AES

D. MD5 encryption algorithm

23. Clark, a professional hacker, attempted to perform a Btlejacking attack using an automated tool, Btlejack, and hardware tool, micro:bit. This attack allowed Clark to hijack, read, and export sensitive information shared between connected devices. To perform this attack, Clark executed various btlejack commands. Which of the following commands was used by Clark to hijack the connections?

A. btlejack -f 0x9c68fd30 -t -m 0xffffffff

B. btlejack -c any

C. btlejack -d /dev/ttyACM0 -d /dev/ttyACM2 -s

D. btlejack -f 0x129f3244 -j

24. Nicolas just found a vulnerability on a public-facing system that is considered a zero-day vulnerability. He sent an email to the owner of the public system describing the problem and how the owner can protect themselves from that vulnerability. He also sent an email to Microsoft informing them of the problem that their systems are exposed to. What type of hacker is Nicolas?

A. Black hat

B. White hat

C. Gray hat

D. Red hat

25. John, a professional hacker, performs a network attack on a renowned organization and gains unauthorized access to the target network. He remains in the network without being detected for a long time and obtains sensitive information without sabotaging the organization. Which of the following attack techniques is used by John?

A. Insider threat

B. Diversion theft

C. Spear-phishing sites

D. Advanced persistent threat

26. Abel, a cloud architect, uses container technology to deploy applications/software including all its dependencies, such as libraries and configuration files, binaries, and other resources that run independently from other processes in the cloud environment. For the containerization of applications, he follows the five-tier container technology architecture. Currently, Abel is verifying and validating image contents, signing images, and sending them to the registries. Which of the following tiers of the container technology architecture is Abel currently working in?

- A. Tier-1: Developer machines
- B. Tier-2: Testing and accreditation systems**
- C. Tier-3: Registries
- D. Tier-4: Orchestrators

27. Jack, a disgruntled ex-employee of Incalsol Ltd., decided to inject fileless malware into Incalsol's systems. To deliver the malware, he used the current employees' email IDs to send fraudulent emails embedded with malicious links that seem to be legitimate. When a victim employee clicks on the link, they are directed to a fraudulent website that automatically loads Flash and triggers the exploit. What is the technique used by Jack to launch the fileless malware on the target systems?

- A. In-memory exploits
- B. Legitimate applications
- C. Script-based injection
- D. Phishing**

28. Lewis, a professional hacker, targeted the IoT cameras and devices used by a target venture-capital firm. He used an information-gathering tool to collect information about the IoT devices connected to a network, open ports and services, and the attack surface area.

Using this tool, he also generated statistical reports on broad usage patterns and trends. This tool helped Lewis continually monitor every reachable server and device on the Internet, further allowing him to exploit these devices in the network. Which of the following tools was employed by Lewis in the above scenario?

- A. NeuVector
- B. Lacework
- C. Censys**
- D. Wapiti

29. CyberTech Inc. recently experienced SQL injection attacks on its official website. The company appointed Bob, a security professional, to build and incorporate defensive strategies against such attacks. Bob adopted a practice whereby only a list of entities such as the data type, range, size, and value, which have been approved for secured access, is accepted. What is the defensive technique employed by Bob in the above scenario?

- A. Whitelist validation**
- B. Output encoding
- C. Blacklist validation
- D. Enforce least privileges

30. What is the port to block first in case you are suspicious that an IoT device has been compromised?

- A. 22
- B. 48101**
- C. 80
- D. 443

31. John, a professional hacker, targeted an organization that uses LDAP for accessing distributed directory services. He used an automated tool to anonymously query the LDAP service for sensitive information such as usernames, addresses, departmental details, and server names to launch further attacks on the target organization. What is the tool employed by John to gather information from the LDAP service?

A. ike-scan

B. Zabasearch

C. JXplorer

D. EarthExplorer

32. Andrew is an Ethical Hacker who was assigned the task of discovering all the active devices hidden by a restrictive firewall in the IPv4 range in a given target network. Which of the following host discovery techniques must he use to perform the given task?

A. UDP scan

B. ARP ping scan

C. ACK flag probe scan

D. TCP Maimon scan

33. There are different ways of pentest of a system, network, or application in information security based on how much information you have about the target. There's black box testing, white box testing, and gray box testing. Which of the statements is true about grey-box testing?

A. The tester only partially knows the internal structure

B. The tester is unaware of the internal structure

C. The tester does not have access at all

D. The tester has full access to the internal structure

34. Bill is a network administrator. He wants to eliminate unencrypted traffic inside his company's network. He decides to setup a SPAN port and capture all traffic to the datacenter. He immediately discovers unencrypted traffic in port UDP 161. What protocol is this port using and how can he secure that traffic?

A. RPC and the best practice is to disable RPC completely.

B. SNMP and he should change it to SNMP V3.

C. SNMP and he should change it to SNMP V2, which is encrypted.

D. It is not necessary to perform any actions, as SNMP is not carrying important information.

35. George is a security professional working for iTech Solutions. He was tasked with securely transferring sensitive data of the organization between industrial systems. In this process, he used a short-range communication protocol based on the IEEE 203.15.4 standard. This protocol is used in devices that transfer data infrequently at a low rate in a restricted area, within a range of 10-100 m. What is the short-range wireless communication technology George employed in the above scenario?

A. LPWAN

B. MQTT

C. NB-IoT

D. Zigbee

36. Jude, a pen tester working in Keiltech Ltd., performs sophisticated security testing on his company's network infrastructure to identify security loopholes. In this process, he started to circumvent the network protection tools and firewalls used in the company. He employed

a technique that can create forged TCP sessions by carrying out multiple SYN, ACK, and RST or FIN packets. Further, this process allowed Jude to execute DDoS attacks that can exhaust the network resources. What is the attack technique used by Jude for finding loopholes in the above scenario?

A. Spoofed session flood attack

B. UDP flood attack

C. Peer-to-peer attack

D. Ping-of-death attack

37. Henry is a cyber security specialist hired by BlackEye – Cyber Security Solutions. He was tasked with discovering the operating system (OS) of a host. He used the Unicornscan tool to discover the OS of the target system. As a result, he obtained a TTL value, which indicates that the target system is running a Windows OS. Identify the TTL value Henry obtained, which indicates that the target OS is Windows.

A. 128

B. 255

C. 64

D. 138

38. In which of the following attacks does an attacker use a method known as the “bricking” of a system, through which he sends emails, IRC chats, tweets, or videos with fraudulent content for hardware updates to the victim?

A. Recursive HTTP GET flood attack

B. SYN flood attack

C. Permanent Denial-of-Service (PDoS) attack

D. UDP flood attack

39. During the enumeration phase, Lawrence performs banner grabbing to obtain information such as OS details and versions of services running. The service that he enumerated runs directly on TCP port 445. Which of the following services is enumerated by Lawrence in this scenario?

A. Remote procedure call (RPC)

B. Telnet

C. Server Message Block (SMB)

D. Network File System (NFS)

40. A newly joined employee, Janet, has been allocated an existing system used by a previous employee. Before issuing the system to Janet, it was assessed by Martin, the administrator. Martin found that there were possibilities of compromise through user directories, registries, and other system parameters. He also identified vulnerabilities such as native configuration tables, incorrect registry or file permissions, and software configuration errors. What is the type of vulnerability assessment performed by Martin?

A. Database assessment

B. Host-based assessment

C. Credentialed assessment

D. Distributed assessment

41. Jane invites her friends Alice and John over for a LAN party. Alice and John access Jane's wireless network without a password. However, Jane has a long, complex password on her router. What attack has likely occurred?

- A. Wardriving
- B. Wireless sniffing
- C. Evil twin**
- D. Piggybacking

42. Samuel, a security administrator, is assessing the configuration of a web server. He noticed that the server permits SSLv2 connections, and the same private key certificate is used on a different server that allows SSLv2 connections. This vulnerability makes the web server vulnerable to attacks as the SSLv2 server can leak key information. Which of the following attacks can be performed by exploiting the above vulnerability?

- A. Padding oracle attack
- B. DROWN attack**
- C. DUHK attack
- D. Side-channel attack

43. Juliet, a security researcher in an organization, was tasked with checking for the authenticity of images to be used in the organization's magazines. She used these images as a search query and tracked the original source and details of the images, which included photographs, profile pictures, and memes. Which of the following footprinting techniques did Rachel use to finish her task?

- A. Google advanced search
- B. Meta search engines
- C. Reverse image search**
- D. Advanced image search

44. Ricardo has discovered the username for an application in his target's environment. As he has a limited amount of time, he decides to attempt to use a list of common passwords he found on the Internet. He compiles them into a list and then feeds that list as an argument into his password-cracking application. What type of attack is Ricardo performing?

A. Brute force

B. Known plaintext

C. Dictionary

D. Password spraying

45. An organization has automated the operation of critical infrastructure from a remote location. For this purpose, all the industrial control systems are connected to the Internet. To empower the manufacturing process, ensure the reliability of industrial networks, and reduce downtime and service disruption, the organization decided to install an OT security tool that further protects against security incidents such as cyber espionage, zero-day attacks, and malware. Which of the following tools must the organization employ to protect its critical infrastructure?

A. Robotium

B. BalenaCloud

C. Flowmon

D. IntentFuzzer

46. Susan, a software developer, wants her web API to update other applications with the latest information. For this purpose, she uses a user-defined HTTP callback or push APIs that are raised based on trigger events; when invoked, this feature supplies data to other applications so that users can instantly receive real-time information. Which of the following techniques is employed by Susan?

A. Web shells

B. Webhooks

C. REST API

D. SOAP API

47. Which of the following Google advanced search operators helps an attacker in gathering information about websites that are similar to a specified target URL?

A. [inurl:]

B. [info:]

C. [site:]

D. [related:]

48. This wireless security protocol allows 192-bit minimum-strength security protocols and cryptographic tools to protect sensitive data, such as GCMP-256, HMAC-SHA384, and ECDSA using a 384-bit elliptic curve. Which is this wireless security protocol?

A. WPA3-Personal

B. WPA3-Enterprise

C. WPA2-Enterprise

D. WPA2-Personal

49. An organization is performing a vulnerability assessment for mitigating threats. James, a pen tester, scanned the organization by building an inventory of the protocols found on the organization's machines to detect which ports are attached to services such as an email server, a web server, or a database server. After identifying these services, he selected the

vulnerabilities on each machine and started executing only the relevant tests. What is the type of vulnerability assessment solution that James employed in the above scenario?

- A. Service-based solutions
- B. Product-based solutions
- C. Tree-based assessment
- D. Inference-based assessment**

50. Bobby, an attacker, targeted a user and decided to hijack and intercept all their wireless communications. He installed a fake communication tower between two authentic endpoints to mislead the victim. Bobby used this virtual tower to interrupt the data transmission between the user and real tower, attempting to hijack an active session. Upon receiving the user's request, Bobby manipulated the traffic with the virtual tower and redirected the victim to a malicious website. What is the attack performed by Bobby in the above scenario?

- A. aLTEr attack**
- B. Jamming signal attack
- C. Wardriving
- D. KRACK attack

51. Mary, a penetration tester, has found password hashes in a client system she managed to breach. She needs to use these passwords to continue with the test, but she does not have time to find the passwords that correspond to these hashes. Which type of attack can she implement in order to continue?

- A. Pass the hash**
- B. Internal monologue attack

C. LLMNR/NBT-NS poisoning

D. Pass the ticket

52. Alice needs to send a confidential document to her coworker, Bryan. Their company has public key infrastructure set up. Therefore, Alice both encrypts the message and digitally signs it. Alice uses _____ to encrypt the message, and Bryan uses _____ to confirm the digital signature.

A. Bryan's public key; Bryan's public key

B. Alice's public key; Alice's public key

C. Bryan's private key; Alice's public key

D. Bryan's public key; Alice's public key

53. Richard, an attacker, aimed to hack IoT devices connected to a target network. In this process, Richard recorded the frequency required to share information between connected devices. After obtaining the frequency, he captured the original data when commands were initiated by the connected devices. Once the original data were collected, he used free tools such as URH to segregate the command sequence. Subsequently, he started injecting the segregated command sequence on the same frequency into the IoT network, which repeats the captured signals of the devices. What is the type of attack performed by Richard in the above scenario?

A. Cryptanalysis attack

B. Reconnaissance attack

C. Side-channel attack

D. Replay attack

54. Steve, an attacker, created a fake profile on a social media website and sent a request to Stella. Stella was enthralled by Steve's profile picture and the description given for his profile, and she initiated a conversation with him soon after accepting the request. After a few days, Steve started asking about her company details and eventually gathered all the essential information regarding her company. What is the social engineering technique Steve employed in the above scenario?

- A. Baiting
- B. Piggybacking
- C. Diversion theft
- D. Honey trap**

55. By performing a penetration test, you gained access under a user account. During the test, you established a connection with your own machine via the SMB service and occasionally entered your login and password in plaintext. Which file do you have to clean to clear the password?

- A. .xsession-log
- B. .profile
- C. .bashrc
- D. .bash_history**

56. Which of the following Metasploit post-exploitation modules can be used to escalate privileges on Windows systems?

- A. getsystem**
- B. getuid
- C. keylogrecorder

D. autoroute

57. You are a penetration tester tasked with testing the wireless network of your client Brakeme SA. You are attempting to break into the wireless network with the SSID `Brakeme-Internal.` You realize that this network uses WPA3 encryption. Which of the following vulnerabilities is the promising to exploit?

A. Cross-site request forgery

B. Dragonblood

C. Key reinstallation attack

D. AP misconfiguration

58. Jason, an attacker, targeted an organization to perform an attack on its Internet-facing web server with the intention of gaining access to backend servers, which are protected by a firewall. In this process, he used a URL `https://xyz.com/feed.php?url=externalsite.com/feed/to` to obtain a remote feed and altered the URL input to the local host to view all the local resources on the target server. What is the type of attack Jason performed in the above scenario?

A. Web server misconfiguration

B. Server-side request forgery (SSRF) attack

C. Web cache poisoning attack

D. Website defacement

59. Annie, a cloud security engineer, uses the Docker architecture to employ a client/server model in the application she is working on. She utilizes a component that can process API requests and handle various Docker objects, such as containers, volumes, images, and

networks. What is the component of the Docker architecture used by Annie in the above scenario?

- A. Docker objects
- B. Docker daemon**
- C. Docker client
- D. Docker registries

60. At what stage of the cyber kill chain theory model does data exfiltration occur?

- A. Weaponization
- B. Actions on objectives**
- C. Command and control
- D. Installation

61. Information gathered from social networking websites such as Facebook, Twitter, and LinkedIn can be used to launch which of the following types of attacks?

- A. Smurf attack
- B. SQL injection attack
- C. Distributed denial of service (DDoS) attack
- D. Social engineering attack**

62. Gerard, a disgruntled ex-employee of Sunglass IT Solutions, targets this organization to perform sophisticated attacks and bring down its reputation in the market. To launch the attacks process, he performed DNS footprinting to gather information about DNS servers and to identify the hosts connected in the target network. He used an automated tool that

can retrieve information about DNS zone data including DNS domain names, computer names, IP addresses, DNS records, and network Whois records. He further exploited this information to launch other sophisticated attacks. What is the tool employed by Gerard in the above scenario?

- A. Towelroot
- B. Knative
- C. zANTI
- D. Bluto**

63. Tony is a penetration tester tasked with performing a penetration test. After gaining initial access to a target system, he finds a list of hashed passwords. Which of the following tools would not be useful for cracking the hashed passwords?

- A. Hashcat
- B. John the Ripper
- C. THC-Hydra
- D. netcat**

64. You are attempting to run an Nmap port scan on a web server. Which of the following commands would result in a scan of common ports with the least amount of noise in order to evade IDS?

- A. `nmap -A -Pn`
- B. `nmap -sP -p-65535 -T5`
- C. `nmap -sT -O -T0`**
- D. `nmap -A --host-timeout 99 -T1`

65. Abel, a security professional, conducts penetration testing in his client organization to check for any security loopholes. He launched an attack on the DHCP servers by broadcasting forged DHCP requests and leased all the DHCP addresses available in the DHCP scope until the server could not issue any more IP addresses. This led to a DoS attack, and as a result, legitimate employees were unable to access the client's network. Which of the following attacks did Abel perform in the above scenario?

A. Rogue DHCP server attack

B. VLAN hopping

C. STP attack

D. DHCP starvation

66. While browsing his Facebook feed, Matt sees a picture one of his friends posted with the caption, `Learn more about your friends!`, as well as a number of personal questions. Matt is suspicious and texts his friend, who confirms that he did indeed post it. With assurance that the post is legitimate, Matt responds to the questions on the post. A few days later, Matt's bank account has been accessed, and the password has been changed. What most likely happened?

A. Matt inadvertently provided the answers to his security questions when responding to the post.

B. Matt inadvertently provided his password when responding to the post.

C. Matt's computer was infected with a keylogger.

D. Matt's bank-account login information was brute forced.

67. You are a penetration tester and are about to perform a scan on a specific server. The agreement that you signed with the client contains the following specific condition for the scan: `The attacker must scan every port on the server several times using a set of spoofed

source IP addresses. Suppose that you are using Nmap to perform this scan. What flag will you use to satisfy this requirement?

- A. The -g flag
- B. The -A flag
- C. The -f flag
- D. The -D flag**

68. Morris, a professional hacker, performed a vulnerability scan on a target organization by sniffing the traffic on the network to identify the active systems, network services, applications, and vulnerabilities. He also obtained the list of the users who are currently accessing the network. What is the type of vulnerability assessment that Morris performed on the target organization?

- A. Credentialed assessment
- B. Internal assessment
- C. External assessment
- D. Passive assessment**

69. Which of the following tools helps security professionals reverse engineer third-party, closed, binary Android apps and allows them to decode resources to their original form and rebuild them after making some modifications?

- A. Lookout Personal
- B. FaceNiff
- C. Apktool**
- D. Promon Shield

70. An attacker utilizes a Wi-Fi Pineapple to run an access point with a legitimate-looking SSID for a nearby business in order to capture the wireless password. What kind of attack is this?

- A. MAC spoofing attack
- B. War driving attack
- C. Phishing attack
- D. Evil-twin attack**

71. Mike, a security engineer, was recently hired by BigFox Ltd. The company recently experienced disastrous DoS attacks. The management had instructed Mike to build defensive strategies for the company's IT infrastructure to thwart DoS/DDoS attacks. Mike deployed some countermeasures to handle jamming and scrambling attacks. What is the countermeasure Mike applied to defend against jamming and scrambling attacks?

- A. Allow the transmission of all types of addressed packets at the ISP level
- B. Disable TCP SYN cookie protection
- C. Allow the usage of functions such as gets and strcpy
- D. Implement cognitive radios in the physical layer**

72. You are a penetration tester working to test the user awareness of the employees of the client XYZ. You harvested two employees' emails from some public sources and are creating a client-side backdoor to send it to the employees via email. Which stage of the cyber kill chain are you at?

- A. Reconnaissance
- B. Weaponization**
- C. Command and control

D. Exploitation

73. Scenario: Joe turns on his home computer to access personal online banking. When he enters the URL `www.bank.com`, the website is displayed, but it prompts him to re-enter his credentials as if he has never visited the site before. When he examines the website URL closer, he finds that the site is not secure and the web address appears different. What type of attack he is experiencing?

- A. DHCP spoofing
- B. DoS attack
- C. ARP cache poisoning
- D. DNS hijacking**

74. Attacker Lauren has gained the credentials of an organization's internal server system, and she was often logging in during irregular times to monitor the network activities. The organization was skeptical about the login times and appointed security professional Robert to determine the issue. Robert analyzed the compromised device to find incident details such as the type of attack, its severity, target, impact, method of propagation, and vulnerabilities exploited. What is the incident handling and response (IH&R) phase, in which Robert has determined these issues?

- A. Incident triage**
- B. Preparation
- C. Incident recording and assignment
- D. Eradication

75. Ethical hacker Jane Smith is attempting to perform an SQL injection attack. She wants to test the response time of a true or false response and wants to use a second command to

determine whether the database will return true or false results for user IDs. Which two SQL injection types would give her the results she is looking for?

- A. Out of band and boolean-based
- B. Union-based and error-based
- C. Time-based and union-based
- D. Time-based and boolean-based**

76. Daniel is a professional hacker who is attempting to perform an SQL injection attack on a target website, www.moviescope.com. During this process, he encountered an IDS that detects SQL injection attempts based on predefined signatures. To evade any comparison statement, he attempted placing characters such as “’or ‘1’=‘1’” in any basic injection statement such as “or 1=1.” Identify the evasion technique used by Daniel in the above scenario.

- A. Char encoding
- B. IP fragmentation

C. Variation

- D. Null byte

77. What would be the fastest way to perform content enumeration on a given web server by using the Gobuster tool?

- A. Performing content enumeration using the bruteforce mode and 10 threads
- B. Performing content enumeration using the bruteforce mode and random file extensions
- C. Skipping SSL certificate verification
- D. Performing content enumeration using a wordlist**

78. When analyzing the IDS logs, the system administrator noticed an alert was logged when the external router was accessed from the administrator's Computer to update the router configuration. What type of an alert is this?

- A. False negative
- B. True negative
- C. True positive
- D. False positive**

79. Widespread fraud at Enron, WorldCom, and Tyco led to the creation of a law that was designed to improve the accuracy and accountability of corporate disclosures. It covers accounting firms and third parties that provide financial services to some organizations and came into effect in 2002. This law is known by what acronym?

- A. SOX**
- B. FedRAMP
- C. HIPAA
- D. PCI DSS

80. There are multiple cloud deployment options depending on how isolated a customer's resources are from those of other customers. Shared environments share the costs and allow each customer to enjoy lower operations expenses. One solution is for a customer to join with a group of users or organizations to share a cloud environment. What is this cloud deployment option called?

- A. Private
- B. Community**
- C. Public

D. Hybrid

81. SQL injection (SQLi) attacks attempt to inject SQL syntax into web requests, which may bypass authentication and allow attackers to access and/or modify data attached to a web application. Which of the following SQLi types leverages a database server's ability to make DNS requests to pass data to an attacker?

- A. In-band SQLi
- B. Union-based SQLi
- C. Out-of-band SQLi**
- D. Time-based blind SQLi

82. Boney, a professional hacker, targets an organization for financial benefits. He performs an attack by sending his session ID using an MITM attack technique. Boney first obtains a valid session ID by logging into a service and later feeds the same session ID to the target employee. The session ID links the target employee to Boney's account page without disclosing any information to the victim. When the target employee clicks on the link, all the sensitive payment details entered in a form are linked to Boney's account. What is the attack performed by Boney in the above scenario?

- A. Forbidden attack
- B. CRIME attack
- C. Session donation attack**
- D. Session fixation attack

83. Attacker Rony installed a rogue access point within an organization's perimeter and attempted to intrude into its internal network. Johnson, a security auditor, identified some unusual traffic in the internal network that is aimed at cracking the authentication

mechanism. He immediately turned off the targeted network and tested for any weak and outdated security mechanisms that are open to attack. What is the type of vulnerability assessment performed by Johnson in the above scenario?

A. Wireless network assessment

B. Application assessment

C. Host-based assessment

D. Distributed assessment

84. Which of the following Bluetooth hacking techniques refers to the theft of information from a wireless device through Bluetooth?

A. Bluesmacking

B. Bluesnarfing

C. Bluejacking

D. Bluebugging

85. Your organization is implementing a vulnerability management program to evaluate and control the risks and vulnerabilities in IT infrastructure. At the moment, your security department is in the vulnerability management lifecycle phase in which is executing the process of applying fixes on vulnerable systems to reduce the impact and severity of vulnerabilities. Which of the following vulnerability-management phases is your security department in?

A. Verification

B. Remediation

C. Vulnerability scan

D. Prioritize Assets

86. Which of the following online tools allows attackers to gather information related to the model of the IoT device and the certifications granted to it?

- A. EarthExplorer
- B. search.com
- C. FCC ID search**
- D. Google image search

87. Heather's company has decided to use a new customer relationship management tool. After performing the appropriate research, they decided to purchase a subscription to a cloud-hosted solution. The only administrative task that Heather will need to perform is the management of user accounts. The provider will take care of the hardware, operating system, and software administration including patching and monitoring. Which of the following is this type of solution?

- A. IaaS
- B. SaaS**
- C. PaaS
- D. CaaS

88. You are using a public Wi-Fi network inside a coffee shop. Before surfing the web, you use your VPN to prevent intruders from sniffing your traffic. If you did not have a VPN, how would you identify whether someone is performing an ARP spoofing attack on your laptop?

- A. You should check your ARP table and see if there is one IP address with two different MAC addresses.**

- B. You should scan the network using Nmap to check the MAC addresses of all the hosts and look for duplicates.
- C. You should use netstat to check for any suspicious connections with another IP address within the LAN.
- D. You cannot identify such an attack and must use a VPN to protect your traffic.

89. Judy created a forum. One day, she discovers that a user is posting strange images without writing comments. She immediately calls a security expert, who discovers that the following code is hidden behind those images: What issue occurred for the users who clicked on the image?

- A. This php file silently executes the code and grabs the user's session cookie and session ID.**
- B. The code redirects the user to another site.
- C. The code injects a new cookie to the browser.
- D. The code is a virus that is attempting to gather the user's username and password.

90. After an audit, the auditors inform you that there is a critical finding that you must tackle immediately. You read the audit report, and the problem is the service running on port 389. Which service is this and how can you tackle the problem?

- A. The service is NTP, and you have to change it from UDP to TCP in order to encrypt it.
- B. The service is LDAP, and you must change it to 636, which is LDAPS.**
- C. The findings do not require immediate actions and are only suggestions.
- D. The service is SMTP, and you must change it to SMIME, which is an encrypted way to send emails.

91. What firewall evasion scanning technique make use of a zombie system that has low network activity as well as its fragment identification numbers?

- A. Packet fragmentation scanning
- B. Spoof source address scanning
- C. Decoy scanning
- D. Idle scanning**

92. Jawad, a system administrator, is learning how to work with new technology: Docker. He will use it to create a network connection between the container interfaces and its parent host interface. Which of the following network drivers is suitable for Jawad?

- A. Bridge networking
- B. Overlay networking
- C. Host networking
- D. Macvlan networking**

93. Suppose that you test an application for the SQL injection vulnerability. You know that the backend database is based on Microsoft SQL Server. In the login/ password form, you enter the following credentials: Based on the above credentials, which of the following SQL commands are you expecting to be executed by the server, if there is indeed an SQL injection vulnerability?

- A. `select * from Users where UserName = 'attack' ' or 1=1 -- and UserPassword = '123456'`
- B. `select * from Users where UserName = 'attack' or 1=1 -- and UserPassword ='123456'`

C. `select * from Users where UserName = 'attack or 1=1 --' and UserPassword = '123456'`

D. `select * from Users where UserName = 'attack' or 1=1 --' and UserPassword = '123456'`

94. Bella, a security professional working at an IT firm, finds that a security breach has occurred while transferring important files. Sensitive data, employee usernames, and passwords are shared in plaintext, paving the way for hackers to perform successful session hijacking. To address this situation, Bella implemented a protocol that sends data using encryption and digital certificates. Which of the following protocols is used by Bella?

A. FTPS

B. FTP

C. HTTPS

D. IP

95. Taylor, a security professional, uses a tool to monitor her company's website, analyze the website's traffic, and track the geographical location of the users visiting the company's website. Which of the following tools did Taylor employ in the above scenario?

A. Webroot

B. Web-Stat

C. WebSite-Watcher

D. WAFW00F

96. While performing an Nmap scan against a host, Paola determines the existence of a firewall. In an attempt to determine whether the firewall is stateful or stateless, which of the following options would be best to use?

- A. -sA**
- B. -sX
- C. -sT
- D. -sF

97. David is a security professional working in an organization, and he is implementing a vulnerability management program in the organization to evaluate and control the risks and vulnerabilities in its IT infrastructure. He is currently executing the process of applying fixes on vulnerable systems to reduce the impact and severity of vulnerabilities. Which phase of the vulnerability-management life cycle is David currently in?

- A. Remediation Most Voted**
- B. Verification
- C. Risk assessment
- D. Vulnerability scan

98. An organization decided to harden its security against web-application and web-server attacks. John, a security personnel in the organization, employed a security scanner to automate web-application security testing and to guard the organization's web infrastructure against web-application threats. Using that tool, he also wants to detect XSS, directory transversal problems, fault injection, SQL injection, attempts to execute commands, and several other attacks. Which of the following security scanners will help John perform the above task?

- A. AlienVault,**

B. Syhunt Hybrid

C. Saleae Logic Analyzer

D. Cisco ASA

99. Infecting a system with malware and using phishing to gain credentials to a system or web application are examples of which phase of the ethical hacking methodology?

A. Scanning

B. Gaining access

C. Maintaining access

D. Reconnaissance

100. Clark is a professional hacker. He created and configured multiple domains pointing to the same host to switch quickly between the domains and avoid detection. Identify the behavior of the adversary in the above scenario.

A. Unspecified proxy activities

B. Use of command-line interface

C. Data staging

D. Use of DNS tunneling

101. Harry, a professional hacker, targets the IT infrastructure of an organization. After preparing for the attack, he attempts to enter the target network using techniques such as sending spear-phishing emails and exploiting vulnerabilities on publicly available servers. Using these techniques, he successfully deployed malware on the target system to establish an outbound connection. What is the APT lifecycle phase that Harry is currently executing?

A. Initial intrusion

B. Persistence

C. Cleanup

D. Preparation

102. Larry, a security professional in an organization, has noticed some abnormalities in the user accounts on a web server. To thwart evolving attacks, he decided to harden the security of the web server by adopting a few countermeasures to secure the accounts on the web server. Which of the following countermeasures must Larry implement to secure the user accounts on the web server?

A. Retain all unused modules and application extensions.

B. Limit the administrator or root-level access to the minimum number of users

C. Enable all non-interactive accounts that should exist but do not require interactive login.

D. Enable unused default user accounts created during the installation of an OS.

103. Gilbert, a web developer, uses a centralized web API to reduce complexity and increase the integrity of updating and changing data. For this purpose, he uses a web service that uses HTTP methods such as PUT, POST, GET, and DELETE and can improve the overall performance, visibility, scalability, reliability, and portability of an application. What is the type of web-service API mentioned in the above scenario?

A. RESTful API

B. JSON-RPC

C. SOAP API

D. REST API

104. This form of encryption algorithm is a symmetric key block cipher that is characterized by a 128-bit block size, and its key size can be up to 256 bits. Which among the following is this encryption algorithm?

- A. HMAC encryption algorithm
- B. Twofish encryption algorithm**
- C. IDEA
- D. Blowfish encryption algorithm

105. Which of the following allows attackers to draw a map or outline the target organization's network infrastructure to know about the actual environment that they are going to hack?

- A. Vulnerability analysis
- B. Malware analysis
- C. Scanning networks**
- D. Enumeration

106. Which file is a rich target to discover the structure of a website during web-server footprinting?

- A. domain.txt
- B. Robots.txt**
- C. Document root
- D. index.html

107. Don, a student, came across a gaming app in a third-party app store and installed it. Subsequently, all the legitimate apps in his smartphone were replaced by deceptive applications that appeared legitimate. He also received many advertisements on his smartphone after installing the app. What is the attack performed on Don in the above scenario?

- A. SIM card attack
- B. Clickjacking
- C. SMS phishing attack
- D. Agent Smith attack**

108. Attacker Simon targeted the communication network of an organization and disabled the security controls of NetNTLMv1 by modifying the values of LMCompatibilityLevel, NTLMMinClientSec, and RestrictSendingNTLMTraffic. He then extracted all the non-network logon tokens from all the active processes to masquerade as a legitimate user to launch further attacks. What is the type of attack performed by Simon?

- A. Combinator attack
- B. Dictionary attack
- C. Rainbow table attack
- D. Internal monologue attack**

109. You are doing research on SQL injection attacks. Which of the following combination of Google operators will you use to find all Wikipedia pages that contain information about SQL, injection attacks, or SQL injection techniques?

- A. SQL injection site:Wikipedia.org**
- B. site:Wikipedia.org intitle:"SQL Injection"

C. allinurl: Wikipedia.org intitle:"SQL Injection"

D. site:Wikipedia.org related:"SQL Injection"

110. Which of the following tools is used by a security professional to encrypt a disk partition to provide confidentiality to the sensitive information stored on it so that the chances of compromising the information are minimized?

A. **FileVault**

B. Nexpose

C. Vindicate

D. Akamai

111. Jude, a pen tester, examined a network from a hacker's perspective to identify exploits and vulnerabilities accessible to the outside world by using devices such as firewalls, routers, and servers. In this process, he also estimated the threat of network security attacks and determined the level of security of the corporate network. What is the type of vulnerability assessment that Jude performed on the organization?

A. Application assessment

B. **External assessment**

C. Passive assessment

D. Host-based assessment

112. Which of the following network attacks relies on sending an abnormally large packet size that exceeds TCP/IP specifications?

A. SYN flooding

B. TCP hijacking

C. Ping of death

D. Smurf attack

113. Given below are the different steps by which an attacker can reveal a hidden SSID using the aircrack-ng suite.

1. Start airodump-ng to discover SSIDs on the interface
2. Run airmmon-ng in the monitor mode
3. Switch to airodump to view the revealed SSID
4. De-authenticate the client to reveal the hidden SSID using Aireplay-ng

What is the correct sequence of steps used for revealing a hidden SSID using the aircrack-ng suite?

- A. 2 -> 1 -> 4 -> 3
- B. 2 -> 3 -> 1 -> 4
- C. 2 -> 4 -> 3 -> 1
- D. 1 -> 2 -> 3 -> 4

114. Hasan, a security professional in an organization, was instructed to simplify the decision-making capability of an organization for identified risks. In the process, he employed a method to scale risk by considering the probability, likelihood, and consequence or impact of the risk. What is the method employed by Hasan for the representation of risk severity?

- A. Risk level
- B. Risk identification
- C. Risk matrix

D. Risk treatment

115. A penetration tester was hired to perform a penetration test for a bank. The tester began searching for IP ranges owned by the bank, performing lookups on the bank's DNS servers, reading news articles online about the bank, watching the bank employees time in and out, searching the bank's job postings (paying special attention to IT-related jobs), and visiting the local dumpster for the bank's corporate office. What phase of the penetration test is the tester currently in?

A. **Passive information gathering**

B. Active information gathering

C. Vulnerability assessment

D. Information reporting

116. Kevin, a professional hacker, wants to penetrate CyberTech Inc's network. He employed a technique, using which he encoded packets with Unicode characters. The company's IDS cannot recognize the packets, but the target web server can decode them. What is the technique used by Kevin to evade the IDS system?

A. Session splicing

B. Urgency flag

C. **Obfuscating**

D. Desynchronization

117. Which of the following commands checks for valid users on an SMTP server?

A. RCPT

B. CHK

C. VRFY

D. EXPM

118. In the Common Vulnerability Scoring System (CVSS) v3.1 severity ratings, what range does medium vulnerability fall in?

A. 4.0-6.0

B. 3.9-6.9

C. 3.0-6.9

D. 4.0-6.9

119. Bob was recently hired by a medical company after it experienced a major cyber security breach. Many patients are complaining that their personal medical records are fully exposed on the Internet and someone can find them with a simple Google search. Bob's boss is very worried because of regulations that protect those data. Which of the following regulations is mostly violated?

A. PCI DSS

B. PII

C. ISO 2002

D. HIPPA/PHI

120. Allen, a professional pen tester, was hired by XpertTech Solutions to perform an attack simulation on the organization's network resources. To perform the attack, he took advantage of the NetBIOS API and targeted the NetBIOS service. By enumerating NetBIOS, he found that port 139 was open and could see the resources that could be accessed or viewed on a remote system. He came across many NetBIOS codes during enumeration.

Identify the NetBIOS code used for obtaining the messenger service running for the logged-in user?

- A. <00>
- B. <20>
- C. <03>**
- D. <18>

121. Which of the following can be designated as "Wireshark for CLI"?

- A. nessus
- B. tcpdump**
- C. John the Ripper
- D. ethereal

122. In this attack, an adversary tricks a victim into reinstalling an already-in-use key. This is achieved by manipulating and replaying cryptographic handshake messages. When the victim reinstalls the key, associated parameters such as the incremental transmit packet number and receive packet number are reset to their initial values. What is this attack called?

- A. Evil Twin
- B. Chop chop attack
- C. Wardriving
- D. KRACK**

123. Techno Security Inc. recently hired John as a penetration tester. He was tasked with identifying open ports in the target network and determining whether the ports are online and any firewall rule sets are encountered. John decided to perform a TCP SYN ping scan on the target network. Which of the following Nmap commands must John use to perform the TCP SYN ping scan?

- A. `nmap -sn -PO < target IP address >`
- B. `nmap -sn -PS < target IP address >`**
- C. `nmap -sn -PA < target IP address >`
- D. `nmap -sn -PP < target IP address >`

124. A dictionary attack is an attack that tries to guess at the key of a ciphertext by attempting many different common passwords and possible passwords that are likely to be used by humans. What would be the fastest way to perform content enumeration on a given web server by using the Gobuster tool?

- A. Performing content enumeration using the bruteforce mode and 10 threads
- B. Performing content enumeration using the bruteforce mode and random file extensions
- C. Skipping SSL certificate verification
- D. Performing content enumeration using a wordlist**

125. What is the file that determines the basic configuration (specifically activities, services, broadcast receivers, etc.) in an Android application?

- A. `AndroidManifest.xml`**
- B. `classes.dex`
- C. `APK.imfo`

D. Resources.asrc